

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - New York Department of Financial Services (NY DFS) 23NYCRR Part 500 (2023 Amendment 2)**

Focal Document URL: https://www.dfs.ny.gov/system/files/documents/2023/10/rf_fs_2amend23NYCRR500_text_20231101.pdf

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-state-ny-dfs-23-nycrr500-2023-amd2.pdf>

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.1	Definitions	[see full text of 23 NYCRR 500 for definitions]	Functional	Intersects With	Standardized Terminology	SEA-02.1	Mechanisms exist to standardize technology and process terminology to reduce confusion amongst groups and departments.	5	
500.2	Cybersecurity Program	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.2(a)	N/A	Each covered entity shall maintain a cybersecurity program designed to protect the confidentiality, integrity and availability of the covered entity's information systems and nonpublic information stored on those information systems.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(b)	N/A	The cybersecurity program shall be based on the covered entity's risk assessment and designed to perform the following core cybersecurity functions:	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(b)(1)	N/A	identify and assess internal and external cybersecurity risks that may threaten the security or integrity of nonpublic information stored on the covered entity's information systems;	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(b)(1)	N/A	identify and assess internal and external cybersecurity risks that may threaten the security or integrity of nonpublic information stored on the covered entity's information systems;	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:	10	
500.2(b)(1)	N/A	identify and assess internal and external cybersecurity risks that may threaten the security or integrity of nonpublic information stored on the covered entity's information systems;	Functional	Intersects With	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	5	
500.2(b)(1)	N/A	identify and assess internal and external cybersecurity risks that may threaten the security or integrity of nonpublic information stored on the covered entity's information systems;	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data	5	
500.2(b)(2)	N/A	use defensive infrastructure and the implementation of policies and procedures to protect the covered entity's information systems, and the nonpublic information stored on those information systems, from unauthorized access, use or other malicious acts;	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(b)(2)	N/A	use defensive infrastructure and the implementation of policies and procedures to protect the covered entity's information systems, and the nonpublic information stored on those information systems, from unauthorized access, use or other malicious acts;	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
500.2(b)(2)	N/A	use defensive infrastructure and the implementation of policies and procedures to protect the covered entity's information systems, and the nonpublic information stored on those information systems, from unauthorized access, use or other malicious acts;	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	5	
500.2(b)(2)	N/A	use defensive infrastructure and the implementation of policies and procedures to protect the covered entity's information systems, and the nonpublic information stored on those information systems, from unauthorized access, use or other malicious acts;	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	
500.2(b)(2)	N/A	use defensive infrastructure and the implementation of policies and procedures to protect the covered entity's information systems, and the nonpublic information stored on those information systems, from unauthorized access, use or other malicious acts;	Functional	Subset Of	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	10	
500.2(b)(2)	N/A	use defensive infrastructure and the implementation of policies and procedures to protect the covered entity's information systems, and the nonpublic information stored on those information systems, from unauthorized access, use or other malicious acts;	Functional	Intersects With	Defense-In-Depth (DiD) Architecture	SEA-03	Mechanisms exist to implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers.	5	
500.2(b)(3)	N/A	detect cybersecurity events;	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(b)(3)	N/A	detect cybersecurity events;	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	
500.2(b)(4)	N/A	respond to identified or detected cybersecurity events to mitigate any negative effects;	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(b)(4)	N/A	respond to identified or detected cybersecurity events to mitigate any negative effects;	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	
500.2(b)(5)	N/A	recover from cybersecurity events and restore normal operations and services; and	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
500.2(b)(5)	N/A	recover from cybersecurity events and restore normal operations and services; and	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(b)(6)	N/A	fulfill applicable regulatory reporting obligations.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
500.2(b)(6)	N/A	fulfill applicable regulatory reporting obligations.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(c)	N/A	Each class A company shall design and conduct independent audits of its cybersecurity program based on its risk assessment.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	Applicable to Class A Companies
500.2(c)	N/A	Each class A company shall design and conduct independent audits of its cybersecurity program based on its risk assessment.	Functional	Subset Of	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant	10	Applicable to Class A Companies
500.2(d)	N/A	A covered entity may meet the requirement(s) of this Part by adopting the relevant and applicable provisions of a cybersecurity program maintained by an affiliate, provided that such provisions satisfy the requirements of this Part, as applicable to the covered entity.	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.2(d)	N/A	A covered entity may meet the requirement(s) of this Part by adopting the relevant and applicable provisions of a cybersecurity program maintained by an affiliate, provided that such provisions satisfy the requirements of this Part, as applicable to the covered entity.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
500.2(d)	N/A	A covered entity may meet the requirement(s) of this Part by adopting the relevant and applicable provisions of a cybersecurity program maintained by an affiliate, provided that such provisions satisfy the requirements of this Part, as applicable to the covered entity.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
500.2(d)	N/A	A covered entity may meet the requirement(s) of this Part by adopting the relevant and applicable provisions of a cybersecurity program maintained by an affiliate, provided that such provisions satisfy the requirements of this Part, as applicable to the covered entity.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCi) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCi) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	
500.2(d)	N/A	A covered entity may meet the requirement(s) of this Part by adopting the relevant and applicable provisions of a cybersecurity program maintained by an affiliate, provided that such provisions satisfy the requirements of this Part, as applicable to the covered entity.	Functional	Intersects With	Outsourcing Non-Essential Functions or Services	SEA-02.2	Mechanisms exist to identify non-essential functions or services that are capable of being outsourced to external service providers and align with the organization's enterprise architecture and security standards.	5	
500.2(e)	N/A	All documentation and information relevant to the covered entity's cybersecurity program, including the relevant and applicable provisions of a cybersecurity program maintained by an affiliate and adopted by the covered entity, shall be made available to the superintendent upon request.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
500.2(e)	N/A	All documentation and information relevant to the covered entity's cybersecurity program, including the relevant and applicable provisions of a cybersecurity program maintained by an affiliate and adopted by the covered entity, shall be made available to the superintendent upon request.	Functional	Intersects With	Legal Assessment of Investigative Inquires	CPL-05	Mechanisms exist to determine whether a government agency has an applicable and valid legal basis to request data from the organization and what further steps need to be taken, if necessary.	5	
500.2(e)	N/A	All documentation and information relevant to the covered entity's cybersecurity program, including the relevant and applicable provisions of a cybersecurity program maintained by an affiliate and adopted by the covered entity, shall be made available to the superintendent upon request.	Functional	Intersects With	Investigation Access Restrictions	CPL-05.2	Mechanisms exist to support official investigations by provisioning government investigators with "least privileges" and "least functionality" to ensure that government investigators only have access to the Technology Assets, Applications, Services and/or Data (TAASD) needed to perform the investigation.	5	
500.2(e)	N/A	All documentation and information relevant to the covered entity's cybersecurity program, including the relevant and applicable provisions of a cybersecurity program maintained by an affiliate and adopted by the covered entity, shall be made available to the superintendent upon request.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.3	Cybersecurity Policy	Each covered entity shall implement and maintain a written policy or policies, approved at least annually by a senior officer or the covered entity's senior governing body for the protection of its information systems and nonpublic information stored on those information systems. Procedures shall be developed, documented and implemented in accordance with the written policy or policies. The cybersecurity policy or policies and procedures shall be based on the covered entity's risk assessment and address, at a minimum, the following areas to the extent applicable to the covered entity's operations:	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
500.3	Cybersecurity Policy	Each covered entity shall implement and maintain a written policy or policies, approved at least annually by a senior officer or the covered entity's senior governing body for the protection of its information systems and nonpublic information stored on those information systems. Procedures shall be developed, documented and implemented in accordance with the written policy or policies. The cybersecurity policy or policies and procedures shall be based on the covered entity's risk assessment and address, at a minimum, the following areas to the extent applicable to the covered entity's operations:	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	8	
500.3(a)	N/A	information security;	Functional	Intersects With	Security, Compliance & Resilience Program (SCRPR)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	5	
500.3(a)	N/A	information security;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(b)	N/A	data governance, classification and retention;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(b)	N/A	data governance, classification and retention;	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	
500.3(c)	N/A	asset inventory, device management and end of life management;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(c)	N/A	asset inventory, device management and end of life management;	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	5	
500.3(d)	N/A	access controls, including remote access and identity management;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(d)	N/A	access controls, including remote access and identity management;	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	5	
500.3(e)	N/A	business continuity and disaster recovery planning and resources;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(e)	N/A	business continuity and disaster recovery planning and resources;	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	5	
500.3(f)	N/A	systems operations and availability concerns;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(f)	N/A	systems operations and availability concerns;	Functional	Intersects With	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	5	
500.3(g)	N/A	systems and network security and monitoring;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(g)	N/A	systems and network security and monitoring;	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	5	
500.3(h)	N/A	security awareness and training;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(h)	N/A	security awareness and training;	Functional	Intersects With	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	5	
500.3(i)	N/A	systems and application security and development and quality assurance;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(i)	N/A	systems and application security and development and quality assurance;	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	
500.3(j)	N/A	physical security and environmental controls;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(j)	N/A	physical security and environmental controls;	Functional	Intersects With	Physical & Environmental Protection	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	
500.3(k)	N/A	customer data privacy;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(k)	N/A	customer data privacy;	Functional	Intersects With	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all	5	
500.3(l)	N/A	vendor and third-party service provider management;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(l)	N/A	vendor and third-party service provider management;	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	
500.3(m)	N/A	risk assessment;	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(m)	N/A	risk assessment;	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned	5	
500.3(n)	N/A	incident response and notification; and	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(n)	N/A	incident response and notification; and	Functional	Intersects With	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	5	
500.3(o)	N/A	vulnerability management.	Functional	Subset Of	Publishing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.3(o)	N/A	vulnerability management.	Functional	Intersects With	Vulnerability & Patch Management Program (VPMF)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	5	
500.4	Chief Information Security Officer.	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.4(a)	N/A	Each covered entity shall designate a CISO. The CISO may be employed by the covered entity, one of its affiliates or a third-party service provider. If the CISO is employed by a third-party service provider or an affiliate, the covered entity shall:	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPR).	5	
500.4(a)(1)	N/A	retain responsibility for compliance with this Part;	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
500.4(a)(1)	N/A	retain responsibility for compliance with this Part;	Functional	Intersects With	Security Compromise Notification Agreements	TPM-05.1	Mechanisms exist to compel External Service Providers (ESPs) to provide notification of actual or potential compromises in the supply chain that can potentially affect or have adversely affected Technology Assets, Applications and/or Services (TAAS) that the organization	5	
500.4(a)(1)	N/A	retain responsibility for compliance with this Part;	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCIC) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCIC) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.4(a)(2)	N/A	designate a senior member of the covered entity's personnel responsible for direction and oversight of the third-party service provider; and	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
500.4(a)(2)	N/A	designate a senior member of the covered entity's personnel responsible for direction and oversight of the third-party service provider; and	Functional	Intersects With	Security Compromise Notification Agreements	TPM-05.1	Mechanisms exist to compel External Service Providers (ESPs) to provide notification of actual or potential compromises in the supply chain that can potentially affect or have adversely affected Technology Assets, Applications and/or Services (TAAS) that the organization	5	
500.4(a)(2)	N/A	designate a senior member of the covered entity's personnel responsible for direction and oversight of the third-party service provider; and	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCi) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCi) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	
500.4(a)(3)	N/A	require the third-party service provider or affiliate to maintain a cybersecurity program that protects the covered entity in accordance with the requirements of this Part.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
500.4(a)(3)	N/A	require the third-party service provider or affiliate to maintain a cybersecurity program that protects the covered entity in accordance with the requirements of this Part.	Functional	Intersects With	Security Compromise Notification Agreements	TPM-05.1	Mechanisms exist to compel External Service Providers (ESPs) to provide notification of actual or potential compromises in the supply chain that can potentially affect or have adversely affected Technology Assets, Applications and/or Services (TAAS) that the organization	5	
500.4(a)(3)	N/A	require the third-party service provider or affiliate to maintain a cybersecurity program that protects the covered entity in accordance with the requirements of this Part.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCi) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCi) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	
500.4(b)	N/A	Report. The CISO of each covered entity shall report in writing at least annually to the senior governing bod on the covered entity's cybersecurity program, including to the extent applicable:	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
500.4(b)	N/A	Report. The CISO of each covered entity shall report in writing at least annually to the senior governing bod on the covered entity's cybersecurity program, including to the extent applicable:	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPR).	5	
500.4(b)	N/A	Report. The CISO of each covered entity shall report in writing at least annually to the senior governing bod on the covered entity's cybersecurity program, including to the extent applicable:	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
500.4(b)	N/A	Report. The CISO of each covered entity shall report in writing at least annually to the senior governing bod on the covered entity's cybersecurity program, including to the extent applicable:	Functional	Intersects With	Authoritative Chain of Command	GOV-04.2	Mechanisms exist to establish an authoritative chain of command with clear lines of communication to remove ambiguity from individuals and teams related to managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
500.4(b)	N/A	Report. The CISO of each covered entity shall report in writing at least annually to the senior governing bod on the covered entity's cybersecurity program, including to the extent applicable:	Functional	Intersects With	Materiality Determination	GOV-16	Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.	5	
500.4(b)	N/A	Report. The CISO of each covered entity shall report in writing at least annually to the senior governing bod on the covered entity's cybersecurity program, including to the extent applicable:	Functional	Intersects With	Material Risks	GOV-16.1	Mechanisms exist to define criteria necessary to designate a risk as a material risk.	5	
500.4(b)	N/A	Report. The CISO of each covered entity shall report in writing at least annually to the senior governing bod on the covered entity's cybersecurity program, including to the extent applicable:	Functional	Intersects With	Material Threats	GOV-16.2	Mechanisms exist to define criteria necessary to designate a threat as a material threat.	5	
500.4(b)(1)	N/A	the confidentiality of nonpublic information and the integrity and security of the covered entity's information systems;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
500.4(b)(1)	N/A	the confidentiality of nonpublic information and the integrity and security of the covered entity's information systems;	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration(1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to subcontractors.	5	
500.4(b)(2)	N/A	the covered entity's cybersecurity policies and procedures;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
500.4(b)(2)	N/A	the covered entity's cybersecurity policies and procedures;	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration(1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to subcontractors.	5	
500.4(b)(3)	N/A	material cybersecurity risks to the covered entity;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
500.4(b)(3)	N/A	material cybersecurity risks to the covered entity;	Functional	Intersects With	Materiality Determination	GOV-16	Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.	5	
500.4(b)(3)	N/A	material cybersecurity risks to the covered entity;	Functional	Intersects With	Material Risks	GOV-16.1	Mechanisms exist to define criteria necessary to designate a risk as a material risk.	5	
500.4(b)(3)	N/A	material cybersecurity risks to the covered entity;	Functional	Intersects With	Material Threats	GOV-16.2	Mechanisms exist to define criteria necessary to designate a threat as a material threat.	5	
500.4(b)(3)	N/A	material cybersecurity risks to the covered entity;	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration(1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to subcontractors.	5	
500.4(b)(4)	N/A	overall effectiveness of the covered entity's cybersecurity program;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
500.4(b)(4)	N/A	overall effectiveness of the covered entity's cybersecurity program;	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration(1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to subcontractors.	5	
500.4(b)(5)	N/A	material cybersecurity events involving the covered entity during the time period addressed by the report; and	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
500.4(b)(5)	N/A	material cybersecurity events involving the covered entity during the time period addressed by the report; and	Functional	Intersects With	Materiality Determination	GOV-16	Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.	5	
500.4(b)(5)	N/A	material cybersecurity events involving the covered entity during the time period addressed by the report; and	Functional	Intersects With	Material Risks	GOV-16.1	Mechanisms exist to define criteria necessary to designate a risk as a material risk.	5	
500.4(b)(5)	N/A	material cybersecurity events involving the covered entity during the time period addressed by the report; and	Functional	Intersects With	Material Threats	GOV-16.2	Mechanisms exist to define criteria necessary to designate a threat as a material threat.	5	
500.4(b)(5)	N/A	material cybersecurity events involving the covered entity during the time period addressed by the report; and	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration(1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to subcontractors.	5	
500.4(b)(6)	N/A	plans for remediating material inadequacies.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
500.4(b)(6)	N/A	plans for remediating material inadequacies.	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
500.4(b)(6)	N/A	plans for remediating material inadequacies.	Functional	Intersects With	Non-Compliance Oversight	CPL-01.1	Mechanisms exist to document and review instances of non-compliance with statutory, regulatory and/or contractual obligations to develop appropriate risk mitigation actions.	5	
500.4(b)(6)	N/A	plans for remediating material inadequacies.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	5	
500.4(b)(6)	N/A	plans for remediating material inadequacies.	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	5	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.4(b)(6)	N/A	plans for remediating material inadequacies.	Functional	Intersects With	Third-Party Deficiency Remediation	TPM-09	Mechanisms exist to address weaknesses or deficiencies in supply chain elements identified during independent or organizational assessments of such elements.	5	
500.4(c)	N/A	The CISO shall timely report to the senior governing body or senior officer(s) on material cybersecurity issues, such as significant cybersecurity events and significant changes to the covered entity's cybersecurity program.	Functional	Subset Of	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPR).	10	
500.4(d)	N/A	The senior governing body of the covered entity shall exercise oversight of the covered entity's cybersecurity risk management, including by:	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	
500.4(d)(1)	N/A	having sufficient understanding of cybersecurity-related matters to exercise such oversight, which may include the use of advisors;	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	
500.4(d)(2)	N/A	requiring the covered entity's executive management or its designees to develop, implement and maintain the covered entity's cybersecurity program;	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	
500.4(d)(3)	N/A	regularly receiving and reviewing management reports about cybersecurity matters; and	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	
500.4(d)(4)	N/A	confirming that the covered entity's management has allocated sufficient resources to implement and maintain an effective cybersecurity program.	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	
500.4(d)(4)	N/A	confirming that the covered entity's management has allocated sufficient resources to implement and maintain an effective cybersecurity program.	Functional	Subset Of	Security, Compliance & Resilience Resource Management	PRM-02	Mechanisms exist to address all capital planning and investment requests, including the resources needed to implement the Security, Compliance & Resilience Program (SCRPR) and document all exceptions to this requirement.	10	
500.4(d)(4)	N/A	confirming that the covered entity's management has allocated sufficient resources to implement and maintain an effective cybersecurity program.	Functional	Intersects With	Allocation of Resources	PRM-03	Mechanisms exist to identify and allocate resources for management, operational, technical and data protection requirements within business process planning for projects / initiatives.	5	
500.5	Vulnerability Management	Each covered entity shall, in accordance with its risk assessment, develop and implement written policies and procedures for vulnerability management that are designed to assess and maintain the effectiveness of its cybersecurity program. These policies and procedures shall be designed to ensure that covered entities:	Functional	Subset Of	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
500.5(a)	N/A	conduct, at a minimum:	Functional	No Relationship	N/A	N/A	N/A	0	
500.5(a)(1)	N/A	penetration testing of their information systems from both inside and outside the information systems' boundaries by a qualified internal or external party at least annually; and	Functional	Intersects With	Attack Surface Scope	VPM-01.1	Mechanisms exist to define and manage the scope for its attack surface management activities.	5	
500.5(a)(1)	N/A	penetration testing of their information systems from both inside and outside the information systems' boundaries by a qualified internal or external party at least annually; and	Functional	Intersects With	Penetration Testing	VPM-07	Mechanisms exist to conduct penetration testing on Technology Assets, Applications and/or Services (TAAS).	8	
500.5(a)(2)	N/A	automated scans of information systems, and a manual review of systems not covered by such scans, for the purpose of discovering, analyzing and reporting vulnerabilities at a frequency determined by the risk assessment, and promptly after any material system changes;	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	8	
500.5(b)	N/A	are promptly informed of new security vulnerabilities by having a monitoring process in place; and	Functional	Intersects With	Commons Vulnerability	VPM-04	Mechanisms exist to address new threats and vulnerabilities on an ongoing basis and ensure assets are protected against known attacks.	5	
500.5(c)	N/A	timely remediate vulnerabilities, giving priority to vulnerabilities based on the risk they pose to the covered entity.	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	5	
500.5(c)	N/A	timely remediate vulnerabilities, giving priority to vulnerabilities based on the risk they pose to the covered entity.	Functional	Intersects With	Vulnerability Ranking	VPM-03	Mechanisms exist to identify and assign a risk ranking to newly discovered security vulnerabilities using reputable outside sources for security vulnerability information.	5	
500.5(c)	N/A	timely remediate vulnerabilities, giving priority to vulnerabilities based on the risk they pose to the covered entity.	Functional	Intersects With	Vulnerability Exploitation Analysis	VPM-03.1	Mechanisms exist to identify, assess, prioritize and document the potential impacts) and (likelihood) of applicable internal and external threats exploiting known vulnerabilities.	5	
500.6	Audit Trail	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.6(a)	N/A	Each covered entity shall securely maintain systems that, to the extent applicable and based on its risk assessment:	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening	5	
500.6(a)(1)	N/A	are designed to reconstruct material financial transactions sufficient to support normal operations and obligations of the covered entity; and are designed to reconstruct material financial transactions sufficient to support normal operations and obligations of the covered entity; and	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	5	
500.6(a)(1)	N/A		Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and	5	
500.6(a)(2)	N/A	include audit trails designed to detect and respond to cybersecurity events that have a reasonable likelihood of materially harming any material part of the normal operations of the covered entity.	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	5	
500.6(a)(2)	N/A	include audit trails designed to detect and respond to cybersecurity events that have a reasonable likelihood of materially harming any material part of the normal operations of the covered entity.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5	
500.6(a)(2)	N/A	include audit trails designed to detect and respond to cybersecurity events that have a reasonable likelihood of materially harming any material part of the normal operations of the covered entity.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and	5	
500.6(b)	N/A	Each covered entity shall maintain records required by paragraph (a)(1) of this section for not fewer than five years and shall maintain records required by paragraph (a)(2) of this section for not fewer than three years.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5	
500.6(b)	N/A	Each covered entity shall maintain records required by paragraph (a)(1) of this section for not fewer than five years and shall maintain records required by paragraph (a)(2) of this section for not fewer than three years.	Functional	Intersects With	Retain Access Records	IAC-01.1	Mechanisms exist to retain a record of personnel accountability to ensure there is a record of all access granted to an individual (system and application-wise), who provided the authorization, when the authorization was granted and when the access was last reviewed.	5	
500.6(b)	N/A	Each covered entity shall maintain records required by paragraph (a)(1) of this section for not fewer than five years and shall maintain records required by paragraph (a)(2) of this section for not fewer than three years.	Functional	Intersects With	Event Log Retention	MON-10	Mechanisms exist to retain event logs for a time period consistent with records retention requirements to provide support for after-the-fact investigations of security incidents and to meet statutory, regulatory and contractual retention requirements.	5	
500.7	Access Privileges	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.7(a)	N/A	As part of its cybersecurity program, based on the covered entity's risk assessment each covered entity shall:	Functional	No Relationship	N/A	N/A	N/A	0	
500.7(a)(1)	N/A	limit user access privileges to information systems that provide access to nonpublic information to only those necessary to perform the user's job;	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
500.7(a)(1)	N/A	limit user access privileges to information systems that provide access to nonpublic information to only those necessary to perform the user's job;	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate	5	
500.7(a)(1)	N/A	limit user access privileges to information systems that provide access to nonpublic information to only those necessary to perform the user's job;	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	5	
500.7(a)(1)	N/A	limit user access privileges to information systems that provide access to nonpublic information to only those necessary to perform the user's job;	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	
500.7(a)(1)	N/A	limit user access privileges to information systems that provide access to nonpublic information to only those necessary to perform the user's job;	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	
500.7(a)(2)	N/A	limit the number of privileged accounts and limit the access functions of privileged accounts to only those necessary to perform the user's job;	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.7(a)(3)	N/A	limit the use of privileged accounts to only when performing functions requiring the use of such access;	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	5	
500.7(a)(4)	N/A	periodically, but at a minimum annually, review all user access privileges and remove or disable accounts and access that are no longer necessary;	Functional	Intersects With	Disable Inactive Accounts	IAC-15.3	Automated mechanisms exist to disable inactive accounts after an organization-defined time period.	5	
500.7(a)(4)	N/A	periodically, but at a minimum annually, review all user access privileges and remove or disable accounts and access that are no longer necessary;	Functional	Intersects With	System Account Reviews	IAC-15.7	Mechanisms exist to review all system accounts and disable any account that cannot be associated with a business process and owner.	5	
500.7(a)(4)	N/A	periodically, but at a minimum annually, review all user access privileges and remove or disable accounts and access that are no longer necessary;	Functional	Intersects With	Privileged Account Inventories	IAC-16.1	Mechanisms exist to inventory all privileged accounts and validate that each person with elevated privileges is authorized by the appropriate level of organizational management.	5	
500.7(a)(5)	N/A	disable or securely configure all protocols that permit remote control of devices; and	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening	5	
500.7(a)(5)	N/A	disable or securely configure all protocols that permit remote control of devices; and	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	
500.7(a)(6)	N/A	promptly terminate access following departures.	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or Services (TAAS) and facilities	5	
500.7(a)(6)	N/A	promptly terminate access following departures.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5	
500.7(b)	N/A	To the extent passwords are employed as a method of authentication, the covered entity shall implement a written password policy that meets industry standards.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
500.7(b)	N/A	To the extent passwords are employed as a method of authentication, the covered entity shall implement a written password policy that meets industry standards.	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	5	
500.7(b)	N/A	To the extent passwords are employed as a method of authentication, the covered entity shall implement a written password policy that meets industry standards.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the	5	
500.7(b)	N/A	To the extent passwords are employed as a method of authentication, the covered entity shall implement a written password policy that meets industry standards.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	
500.7(c)	N/A	Each class A company shall monitor privileged access activity and shall implement:	Functional	Intersects With	Privileged User Oversight	MON-01.15	Mechanisms exist to implement enhanced activity monitoring for privileged users.	5	Applicable to Class A Companies
500.7(c)	N/A	Each class A company shall monitor privileged access activity and shall implement:	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient	5	Applicable to Class A Companies
500.7(c)	N/A	Each class A company shall monitor privileged access activity and shall implement:	Functional	Intersects With	Privileged Functions Logging	MON-03.3	Mechanisms exist to log and review the actions of users and/or services with elevated privileges.	5	Applicable to Class A Companies
500.7(c)(1)	N/A	a privileged access management solution; and	Functional	Equal	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	
500.7(c)(2)	N/A	an automated method of blocking commonly used passwords for all accounts on information systems owned or controlled by the class A company and wherever feasible for all other accounts. To the extent the class A company determines that blocking commonly used passwords is infeasible, the covered entity's CISO may instead approve in writing at least annually the infeasibility and the use of reasonably equivalent or more secure compensating controls.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based	5	Applicable to Class A Companies
500.7(c)(2)	N/A	an automated method of blocking commonly used passwords for all accounts on information systems owned or controlled by the class A company and wherever feasible for all other accounts. To the extent the class A company determines that blocking commonly used passwords is infeasible, the covered entity's CISO may instead approve in writing at least annually the infeasibility and the use of reasonably equivalent or more secure compensating controls.	Functional	Intersects With	Automated Support For Password Strength	IAC-10.4	Automated mechanisms exist to determine if password authenticators are sufficiently strong enough to satisfy organization-defined password length and complexity requirements.	5	Applicable to Class A Companies
500.8	Application Security	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.8(a)	N/A	Each covered entity's cybersecurity program shall include written procedures, guidelines and standards designed to ensure the use of secure development practices for in-house developed applications utilized by the covered entity, and procedures for evaluating, assessing or testing the security of externally developed applications utilized by the covered entity within the context of the covered entity's technology environment.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
500.8(a)	N/A	Each covered entity's cybersecurity program shall include written procedures, guidelines and standards designed to ensure the use of secure development practices for in-house developed applications utilized by the covered entity, and procedures for evaluating, assessing or testing the security of externally developed applications utilized by the covered entity within the context of the covered entity's technology environment.	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	5	
500.8(a)	N/A	Each covered entity's cybersecurity program shall include written procedures, guidelines and standards designed to ensure the use of secure development practices for in-house developed applications utilized by the covered entity, and procedures for evaluating, assessing or testing the security of externally developed applications utilized by the covered entity within the context of the covered entity's technology environment.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	
500.8(a)	N/A	Each covered entity's cybersecurity program shall include written procedures, guidelines and standards designed to ensure the use of secure development practices for in-house developed applications utilized by the covered entity, and procedures for evaluating, assessing or testing the security of externally developed applications utilized by the covered entity within the context of the covered entity's technology environment.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	
500.8(a)	N/A	Each covered entity's cybersecurity program shall include written procedures, guidelines and standards designed to ensure the use of secure development practices for in-house developed applications utilized by the covered entity, and procedures for evaluating, assessing or testing the security of externally developed applications utilized by the covered entity within the context of the covered entity's technology environment.	Functional	Intersects With	Software Design Review	TDA-06.5	Mechanisms exist to have an independent review of the software design to validate: (1) Applicable security, compliance and resilience requirements are met; and (2) Identified risks are remediated.	5	
500.8(a)	N/A	Each covered entity's cybersecurity program shall include written procedures, guidelines and standards designed to ensure the use of secure development practices for in-house developed applications utilized by the covered entity, and procedures for evaluating, assessing or testing the security of externally developed applications utilized by the covered entity within the context of the covered entity's technology environment.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and	5	
500.8(a)	N/A	Each covered entity's cybersecurity program shall include written procedures, guidelines and standards designed to ensure the use of secure development practices for in-house developed applications utilized by the covered entity, and procedures for evaluating, assessing or testing the security of externally developed applications utilized by the covered entity within the context of the covered entity's technology environment.	Functional	Intersects With	Secure Settings By Default	TDA-09.6	Mechanisms exist to implement secure configuration settings by default to reduce the likelihood of Technology Assets, Applications and/or Services (TAAS) being deployed with weak security settings that would put the TAAS at a greater risk of compromise.	5	
500.8(b)	N/A	All such procedures, guidelines and standards shall be reviewed, assessed and updated as necessary by the CISO (or a qualified designee) of the covered entity at least annually.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRPP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.9	Risk Assessment	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.9(a)	N/A	Each covered entity shall conduct a periodic risk assessment of the covered entity's information systems sufficient to inform the design of the cybersecurity program as required by this Part. Such risk assessment shall be reviewed and updated as reasonably necessary, but at a minimum annually, and whenever a change in the business or technology causes a material change to the covered entity's cyber risk. The covered entity's risk assessment shall allow for revision of controls to respond to technological developments and evolving threats and shall consider the particular risks of the covered entity's business operations related to cybersecurity, nonpublic information collected or stored, information systems utilized and the availability and effectiveness of controls to protect nonpublic information and information systems.	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	
500.9(a)	N/A	Each covered entity shall conduct a periodic risk assessment of the covered entity's information systems sufficient to inform the design of the cybersecurity program as required by this Part. Such risk assessment shall be reviewed and updated as reasonably necessary, but at a minimum annually, and whenever a change in the business or technology causes a material change to the covered entity's cyber risk. The covered entity's risk assessment shall allow for revision of controls to respond to technological developments and evolving threats and shall consider the particular risks of the covered entity's business operations related to cybersecurity, nonpublic information collected or stored, information systems utilized and the availability and effectiveness of controls to protect nonpublic information and information systems.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
500.9(a)	N/A	Each covered entity shall conduct a periodic risk assessment of the covered entity's information systems sufficient to inform the design of the cybersecurity program as required by this Part. Such risk assessment shall be reviewed and updated as reasonably necessary, but at a minimum annually, and whenever a change in the business or technology causes a material change to the covered entity's cyber risk. The covered entity's risk assessment shall allow for revision of controls to respond to technological developments and evolving threats and shall consider the particular risks of the covered entity's business operations related to cybersecurity, nonpublic information collected or stored, information systems utilized and the availability and effectiveness of controls to protect nonpublic information and information systems.	Functional	Intersects With	Risk Register	RSK-04.1	Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.	5	
500.9(a)	N/A	Each covered entity shall conduct a periodic risk assessment of the covered entity's information systems sufficient to inform the design of the cybersecurity program as required by this Part. Such risk assessment shall be reviewed and updated as reasonably necessary, but at a minimum annually, and whenever a change in the business or technology causes a material change to the covered entity's cyber risk. The covered entity's risk assessment shall allow for revision of controls to respond to technological developments and evolving threats and shall consider the particular risks of the covered entity's business operations related to cybersecurity, nonpublic information collected or stored, information systems utilized and the availability and effectiveness of controls to protect nonpublic information and information systems.	Functional	Intersects With	Risk Assessment Update	RSK-07	Mechanisms exist to routinely update risk assessments and react accordingly upon identifying new security vulnerabilities, including using outside sources for security vulnerability information.	5	
500.9(b)	N/A	The risk assessment shall be carried out in accordance with written policies and procedures and shall be documented. Such policies and procedures shall include:	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	
500.9(b)	N/A	The risk assessment shall be carried out in accordance with written policies and procedures and shall be documented. Such policies and procedures shall include:	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Materiality Determination	GOV-16	Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Material Risks	GOV-16.1	Mechanisms exist to define criteria necessary to designate a risk as a material risk.	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Material Threats	GOV-16.2	Mechanisms exist to define criteria necessary to designate a threat as a material threat.	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Risk Tolerance	RSK-01.3	Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Risk Threshold	RSK-01.4	Mechanisms exist to define organizational risk threshold, the level of risk exposure above which risks are addressed and below which risks	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Risk Appetite	RSK-01.5	Mechanisms exist to define organizational risk appetite, the degree of uncertainty the organization is willing to accept in anticipation of a reward.	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Risk Catalog	RSK-03.1	Mechanisms exist to develop and keep current a catalog of applicable risks associated with the organization's business operations and	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Threat Catalog	THR-09	Mechanisms exist to develop and keep current a catalog of applicable internal and external threats to the organization, both natural and manmade.	5	
500.9(b)(1)	N/A	criteria for the evaluation and categorization of identified cybersecurity risks or threats facing the covered entity;	Functional	Intersects With	Threat Analysis	THR-10	Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.	5	
500.9(b)(2)	N/A	criteria for the assessment of the confidentiality, integrity, security and availability of the covered entity's information systems and nonpublic information, including the adequacy of existing controls in the context	Functional	Intersects With	Materiality Determination	GOV-16	Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.	5	
500.9(b)(2)	N/A	criteria for the assessment of the confidentiality, integrity, security and availability of the covered entity's information systems and nonpublic information, including the adequacy of existing controls in the context of identified risks; and	Functional	Intersects With	Material Risks	GOV-16.1	Mechanisms exist to define criteria necessary to designate a risk as a material risk.	5	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.9(b)(2)	N/A	criteria for the assessment of the confidentiality, integrity, security and availability of the covered entity's information systems and nonpublic information, including the adequacy of existing controls in the context of identified risks; and	Functional	Intersects With	Material Threats	GOV-16.2	Mechanisms exist to define criteria necessary to designate a threat as a material threat.	5	
500.9(b)(2)	N/A	criteria for the assessment of the confidentiality, integrity, security and availability of the covered entity's information systems and nonpublic information, including the adequacy of existing controls in the context of identified risks; and	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data	5	
500.9(b)(3)	N/A	requirements describing how identified risks will be mitigated or accepted based on the risk assessment and how the cybersecurity program will address the risks.	Functional	Intersects With	Exception Management	GOV-02.1	Mechanisms exist to prohibit exceptions to standards, except when the exception has been formally assessed for risk impact, approved and recorded.	5	
500.9(b)(3)	N/A	requirements describing how identified risks will be mitigated or accepted based on the risk assessment and how the cybersecurity program will address the risks.	Functional	Intersects With	Risk-Based Security Categorization	RSK-02	Mechanisms exist to categorize Technology Assets, Applications, Services and/or Data (TAASD) in accordance with applicable laws, regulations and contractual obligations that:	5	
500.9(b)(3)	N/A	requirements describing how identified risks will be mitigated or accepted based on the risk assessment and how the cybersecurity program will address the risks.	Functional	Intersects With	Impact-Level Prioritization	RSK-02.1	Mechanisms exist to prioritize the impact level for Technology Assets, Applications and/or Services (TAAS) to prevent potential disruptions.	5	
500.9(b)(3)	N/A	requirements describing how identified risks will be mitigated or accepted based on the risk assessment and how the cybersecurity program will address the risks.	Functional	Intersects With	Risk Ranking	RSK-05	Mechanisms exist to identify and assign a risk ranking to newly discovered security vulnerabilities that is based on industry-recognized practices.	5	
500.9(b)(3)	N/A	requirements describing how identified risks will be mitigated or accepted based on the risk assessment and how the cybersecurity program will address the risks.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	5	
500.9(b)(3)	N/A	requirements describing how identified risks will be mitigated or accepted based on the risk assessment and how the cybersecurity program will address the risks.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related:	5	
500.9(b)(3)	N/A	requirements describing how identified risks will be mitigated or accepted based on the risk assessment and how the cybersecurity program will address the risks.	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	5	
500.10	Cybersecurity Personnel and Intelligence	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.10(a)	N/A	In addition to the requirements set forth in section 500.4(a) of this Part, each covered entity shall:	Functional	No Relationship	N/A	N/A	N/A	0	
500.10(a)(1)	N/A	utilize qualified cybersecurity personnel of the covered entity, an affiliate or a third-party service provider sufficient to manage the covered entity's cybersecurity risks and to perform or oversee the performance of the core cybersecurity functions specified in section 500.2(b)(1)-(6) of this Part;	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10	
500.10(a)(1)	N/A	utilize qualified cybersecurity personnel of the covered entity, an affiliate or a third-party service provider sufficient to manage the covered entity's cybersecurity risks and to perform or oversee the performance of the core cybersecurity functions specified in section 500.2(b)(1)-(6) of this Part;	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	
500.10(a)(1)	N/A	utilize qualified cybersecurity personnel of the covered entity, an affiliate or a third-party service provider sufficient to manage the covered entity's cybersecurity risks and to perform or oversee the performance of the core cybersecurity functions specified in section 500.2(b)(1)-(6) of this Part;	Functional	Intersects With	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	5	
500.10(a)(1)	N/A	utilize qualified cybersecurity personnel of the covered entity, an affiliate or a third-party service provider sufficient to manage the covered entity's cybersecurity risks and to perform or oversee the performance of the core cybersecurity functions specified in section 500.2(b)(1)-(6) of this Part;	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined personnel screening criteria.	5	
500.10(a)(1)	N/A	utilize qualified cybersecurity personnel of the covered entity, an affiliate or a third-party service provider sufficient to manage the covered entity's cybersecurity risks and to perform or oversee the performance of the core cybersecurity functions specified in section 500.2(b)(1)-(6) of this Part;	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
500.10(a)(1)	N/A	utilize qualified cybersecurity personnel of the covered entity, an affiliate or a third-party service provider sufficient to manage the covered entity's cybersecurity risks and to perform or oversee the performance of the core cybersecurity functions specified in section 500.2(b)(1)-(6) of this Part;	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
500.10(a)(1)	N/A	utilize qualified cybersecurity personnel of the covered entity, an affiliate or a third-party service provider sufficient to manage the covered entity's cybersecurity risks and to perform or oversee the performance of the core cybersecurity functions specified in section 500.2(b)(1)-(6) of this Part;	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASC) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	5	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	5	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training:	5	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Intersects With	Sensitive / Regulated Data Storage, Handling & Processing	SAT-03.3	(1) Before authorizing access to the system or performing assigned processing, storing or transmitting sensitive and/or regulated data is formally trained in data handling requirements.	5	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Intersects With	Privileged Users	SAT-03.5	Mechanisms exist to provide specific training for privileged users to ensure privileged users understand their unique roles and responsibilities.	5	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Intersects With	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day business operations.	5	
500.10(a)(2)	N/A	provide cybersecurity personnel with cybersecurity updates and training sufficient to address relevant cybersecurity risks; and	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures.	5	
500.10(a)(3)	N/A	verify that key cybersecurity personnel take steps to maintain current knowledge of changing cybersecurity threats and countermeasures.	Functional	Intersects With	Continuing Professional Education (CPE) - Security, Compliance & Resilience Personnel	SAT-03.7	Mechanisms exist to ensure security, compliance and resilience personnel receive Continuing Professional Education (CPE) training to maintain currency and proficiency with industry-recognized security practices that are pertinent to their assigned roles and responsibilities.	5	
500.10(a)(3)	N/A	verify that key cybersecurity personnel take steps to maintain current knowledge of changing cybersecurity threats and countermeasures.	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response	5	
500.10(b)	N/A	A covered entity may choose to utilize an affiliate or qualified third-party service provider to assist in complying with the requirements set forth in this Part, subject to the requirements set forth in sections 500.4 and 500.11 of this Part.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
500.10(b)	N/A	A covered entity may choose to utilize an affiliate or qualified third-party service provider to assist in complying with the requirements set forth in this Part, subject to the requirements set forth in sections 500.4 and 500.11 of this Part.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASC) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and	5	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.10(b)	N/A	A covered entity may choose to utilize an affiliate or qualified third-party service provider to assist in complying with the requirements set forth in this Part, subject to the requirements set forth in sections 500.4 and 500.11 of this Part.	Functional	Intersects With	Third-Party Personnel Security	TPM-06	Mechanisms exist to control personnel security requirements including security roles and responsibilities for third-party providers.	5	
500.11	Third Party Service Provider Security Policy	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.11(a)	N/A	Each covered entity shall implement written policies and procedures designed to ensure the security of information systems and nonpublic information.	Functional	Subset Of	Information Security, Compliance & Governance	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and	10	
500.11(a)	N/A	Each covered entity shall implement written policies and procedures designed to ensure the security of information systems and nonpublic information that are accessible to, or held by, third-party service providers. Such policies and procedures shall be based on the risk assessment of the covered entity and shall address to the extent applicable:	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	
500.11(a)(1)	N/A	the identification and risk assessment of third-party service providers;	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
500.11(a)(1)	N/A	the identification and risk assessment of third-party service providers;	Functional	Intersects With	Third-Party Inventories	TPM-01.1	Mechanisms exist to maintain a current, accurate and complete list of External Service Providers (ESPs) that can potentially impact the	5	
500.11(a)(1)	N/A	the identification and risk assessment of third-party service providers;	Functional	Intersects With	Third-Party Criticality Assessments	TPM-02	Mechanisms exist to identify, prioritize and assess suppliers and partners of critical Technology Assets, Applications and/or Services (TAAS) using a supply chain risk assessment process relative to their importance in supporting the delivery of high-value services.	5	
500.11(a)(1)	N/A	the identification and risk assessment of third-party service providers;	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
500.11(a)(1)	N/A	the identification and risk assessment of third-party service providers;	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications	5	
500.11(a)(1)	N/A	the identification and risk assessment of third-party service providers;	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets,	5	
500.11(a)(1)	N/A	the identification and risk assessment of third-party service providers;	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
500.11(a)(2)	N/A	minimum cybersecurity practices required to be met by such third-party service providers in order for them to do business with the covered entity;	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets,	5	
500.11(a)(2)	N/A	minimum cybersecurity practices required to be met by such third-party service providers in order for them to do business with the covered entity;	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
500.11(a)(3)	N/A	due diligence processes used to evaluate the adequacy of cybersecurity practices of such third-party service providers; and	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5	
500.11(a)(3)	N/A	due diligence processes used to evaluate the adequacy of cybersecurity practices of such third-party service providers; and	Functional	Intersects With	Third-Party Scope Review	TPM-05.5	Mechanisms exist to perform recurring validation of the Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to ensure security, compliance and resilience	5	
500.11(a)(3)	N/A	due diligence processes used to evaluate the adequacy of cybersecurity practices of such third-party service providers; and	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration(1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to subcontractors.	5	
500.11(a)(3)	N/A	due diligence processes used to evaluate the adequacy of cybersecurity practices of such third-party service providers; and	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	5	
500.11(a)(4)	N/A	periodic assessment of such third-party service providers based on the risk they present and the continued adequacy of their cybersecurity practices.	Functional	Intersects With	Third-Party Criticality Assessments	TPM-02	Mechanisms exist to identify, prioritize and assess suppliers and partners of critical Technology Assets, Applications and/or Services (TAAS) using a supply chain risk assessment process relative to their	5	
500.11(a)(4)	N/A	periodic assessment of such third-party service providers based on the risk they present and the continued adequacy of their cybersecurity practices.	Functional	Intersects With	Third-Party Scope Review	TPM-05.5	Mechanisms exist to perform recurring validation of the Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to ensure security, compliance and resilience control assignments accurately reflect current:	5	
500.11(a)(4)	N/A	periodic assessment of such third-party service providers based on the risk they present and the continued adequacy of their cybersecurity practices.	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	5	
500.11(b)	N/A	Such policies and procedures shall include relevant guidelines for due diligence and/or contractual protections relating to third-party service providers including to the extent applicable guidelines addressing:	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
500.11(b)	N/A	Such policies and procedures shall include relevant guidelines for due diligence and/or contractual protections relating to third-party service providers including to the extent applicable guidelines addressing:	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets,	5	
500.11(b)	N/A	Such policies and procedures shall include relevant guidelines for due diligence and/or contractual protections relating to third-party service providers including to the extent applicable guidelines addressing:	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
500.11(b)(1)	N/A	the third-party service provider's policies and procedures for access controls, including its use of multi-factor authentication as required by section 500.12 of this Part, to limit access to relevant information	Functional	Subset Of	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access;	10	
500.11(b)(1)	N/A	the third-party service provider's policies and procedures for access controls, including its use of multi-factor authentication as required by section 500.12 of this Part, to limit access to relevant information systems and nonpublic information;	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
500.11(b)(1)	N/A	the third-party service provider's policies and procedures for access controls, including its use of multi-factor authentication as required by section 500.12 of this Part, to limit access to relevant information systems and nonpublic information;	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
500.11(b)(1)	N/A	the third-party service provider's policies and procedures for access controls, including its use of multi-factor authentication as required by section 500.12 of this Part, to limit access to relevant information systems and nonpublic information;	Functional	Intersects With	Third-Party Authentication Practices	TPM-05.3	Mechanisms exist to ensure External Service Providers (ESPs) use unique authentication factors for each of its customers.	5	
500.11(b)(2)	N/A	the third-party service provider's policies and procedures for use of encryption as required by section 500.15 of this Part to protect nonpublic information in transit and at rest;	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	5	
500.11(b)(2)	N/A	the third-party service provider's policies and procedures for use of encryption as required by section 500.15 of this Part to protect nonpublic information in transit and at rest;	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets,	5	
500.11(b)(2)	N/A	the third-party service provider's policies and procedures for use of encryption as required by section 500.15 of this Part to protect nonpublic information in transit and at rest;	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
500.11(b)(3)	N/A	notice to be provided to the covered entity in the event of a cybersecurity event directly impacting the covered entity's information systems or the covered entity's nonpublic information being held by the	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets,	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - New York Department of Financial Services (NY DFS) 23NYCRR Part 500 (2023 Amendment 2)**

Focal Document URL: https://www.dfs.ny.gov/system/files/documents/2023/10/rf_fs_2amend23NYCRR500_text_20231101.pdf

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-state-ny-dfs-23-nycrr500-2023-amd2.pdf>

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.11(b)(3)	N/A	notice to be provided to the covered entity in the event of a cybersecurity event directly impacting the covered entity's information systems or the covered entity's nonpublic information being held by the third-party service provider; and	Functional	Intersects With	Security Compromise Notification Agreements	TPM-05.1	Mechanisms exist to compel External Service Providers (ESPs) to provide notification of actual or potential compromises in the supply chain that can potentially affect or have adversely affected Technology Assets, Applications and/or Services (TAAS) that the organization	5	
500.11(b)(3)	N/A	notice to be provided to the covered entity in the event of a cybersecurity event directly impacting the covered entity's information systems or the covered entity's nonpublic information being held by the third-party service provider; and	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
500.11(b)(4)	N/A	representations and warranties addressing the third-party service provider's cybersecurity policies and procedures that relate to the security of the covered entity's information systems or nonpublic information.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
500.11(b)(4)	N/A	representations and warranties addressing the third-party service provider's cybersecurity policies and procedures that relate to the security of the covered entity's information systems or nonpublic information.	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
500.11(b)(4)	N/A	representations and warranties addressing the third-party service provider's cybersecurity policies and procedures that relate to the security of the covered entity's information systems or nonpublic information.	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration(1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including	5	
500.12	Multi-Factor Authentication	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.12(a)	N/A	Multi-factor authentication shall be utilized for any individual accessing any information systems of a covered entity, unless the covered entity remote access to the covered entity's information systems;	Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for:	5	
500.12(a)(1)	N/A		Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access; (2) Third-party Technology Assets, Applications and/or Services (TAAS); and/or (3) Non-console access to critical TAAS that store, transmit and/or	5	
500.12(a)(2)	N/A	remote access to third-party applications, including but not limited to those that are cloud based, from which nonpublic information is accessible; and	Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access; (2) Third-party Technology Assets, Applications and/or Services (TAAS); and/or (3) Non-console access to critical TAAS that store, transmit and/or	5	
500.12(a)(3)	N/A	all privileged accounts other than service accounts that prohibit interactive login.	Functional	Intersects With	Network Access to Privileged Accounts	IAC-06.1	Mechanisms exist to utilize Multi-Factor Authentication (MFA) to authenticate network access for privileged accounts.	5	
500.12(a)(3)	N/A	all privileged accounts other than service accounts that prohibit interactive login.	Functional	Intersects With	Local Access to Privileged Accounts	IAC-06.3	Mechanisms exist to utilize Multi-Factor Authentication (MFA) to authenticate local access for privileged accounts.	5	
500.12(b)	N/A	If the covered entity has a CISO, the CISO may approve in writing the use of reasonably equivalent or more secure compensating controls. Such	Functional	Intersects With	Exception Management	GOV-02.1	Mechanisms exist to prohibit exceptions to standards, except when the exception has been formally assessed for risk impact, approved and	5	
500.12(b)	N/A	If the covered entity has a CISO, the CISO may approve in writing the use of reasonably equivalent or more secure compensating controls. Such controls shall be reviewed periodically, but at a minimum annually.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	5	
500.12(b)	N/A	If the covered entity has a CISO, the CISO may approve in writing the use of reasonably equivalent or more secure compensating controls. Such controls shall be reviewed periodically, but at a minimum annually.	Functional	Subset Of	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	10	
500.13	Asset Management and Data Retention Requirements	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.13(a)	N/A	As part of its cybersecurity program, each covered entity shall implement written policies and procedures designed to produce and maintain a complete, accurate and documented asset inventory of the	Functional	Intersects With	Posturing Security, Compliance & Resilience	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
500.13(a)	N/A	As part of its cybersecurity program, each covered entity shall implement written policies and procedures designed to produce and maintain a complete, accurate and documented asset inventory of the covered entity's information systems. The asset inventory shall be maintained in accordance with written policies and procedures. At a minimum, such policies and procedures shall include:	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	5	
500.13(a)	N/A	As part of its cybersecurity program, each covered entity shall implement written policies and procedures designed to produce and maintain a complete, accurate and documented asset inventory of the covered entity's information systems. The asset inventory shall be maintained in accordance with written policies and procedures. At a minimum, such policies and procedures shall include:	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and	5	
500.13(a)(1)	N/A	a method to track key information for each asset, including, as applicable, the following:	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) is available for review and audit by designated organizational personnel.	5	
500.13(a)(1)(i)	N/A	owner;	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) is available for review and audit by designated organizational personnel.	5	
500.13(a)(1)(ii)	N/A	location;	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) is available for review and audit by designated organizational personnel.	5	
500.13(a)(1)(iii)	N/A	classification or sensitivity;	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) is available for review and audit by designated organizational personnel.	5	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.13(a)(1)(iv)	N/A	support expiration date; and	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	5	
500.13(a)(1)(v)	N/A	recovery time objectives; and	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	5	
500.13(a)(2)	N/A	the frequency required to update and validate the covered entity's asset inventory.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	5	
500.13(b)	N/A	As part of its cybersecurity program, each covered entity shall include policies and procedures for the secure disposal on a periodic basis of any nonpublic information identified in section 500.1(k)(2)–(3) of this Part that is no longer necessary for business operations or for other legitimate business purposes of the covered entity, except where such information is otherwise required to be retained by law or regulation, or where targeted disposal is not reasonably feasible due to the manner in which the information is maintained.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	
500.13(b)	N/A	As part of its cybersecurity program, each covered entity shall include policies and procedures for the secure disposal on a periodic basis of any nonpublic information identified in section 500.1(k)(2)–(3) of this Part that is no longer necessary for business operations or for other legitimate business purposes of the covered entity, except where such information is otherwise required to be retained by law or regulation, or where targeted disposal is not reasonably feasible due to the manner in which the information is maintained.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5	
500.14	Training and Monitoring	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.14(a)	N/A	As part of its cybersecurity program, each covered entity shall:	Functional	No Relationship	N/A	N/A	N/A	0	
500.14(a)(1)	N/A	implement risk-based policies, procedures and controls designed to monitor the activity of authorized users and detect unauthorized access or use of, or tampering with, nonpublic information by such authorized users;	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
500.14(a)(1)	N/A	implement risk-based policies, procedures and controls designed to monitor the activity of authorized users and detect unauthorized access or use of, or tampering with, nonpublic information by such authorized users;	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	5	
500.14(a)(1)	N/A	implement risk-based policies, procedures and controls designed to monitor the activity of authorized users and detect unauthorized access or use of, or tampering with, nonpublic information by such authorized users;	Functional	Intersects With	Suspicious Communications & Anomalous System Behavior	SAT-03.2	Mechanisms exist to provide training to personnel on organization-defined indicators of malware to recognize suspicious communications and anomalous behavior.	5	
500.14(a)(2)	N/A	implement risk-based controls designed to protect against malicious code, including those that monitor and filter web traffic and electronic mail to block malicious content; and	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	
500.14(a)(2)	N/A	implement risk-based controls designed to protect against malicious code, including those that monitor and filter web traffic and electronic mail to block malicious content; and	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	
500.14(a)(2)	N/A	implement risk-based controls designed to protect against malicious code, including those that monitor and filter web traffic and electronic mail to block malicious content; and	Functional	Intersects With	Phishing & Spam Protection	END-08	Mechanisms exist to utilize anti-phishing and spam protection technologies to detect and take action on unsolicited messages transported by electronic mail.	5	
500.14(a)(2)	N/A	implement risk-based controls designed to protect against malicious code, including those that monitor and filter web traffic and electronic mail to block malicious content; and	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	5	
500.14(a)(2)	N/A	implement risk-based controls designed to protect against malicious code, including those that monitor and filter web traffic and electronic mail to block malicious content; and	Functional	Intersects With	DNS & Content Filtering	NET-18	Mechanisms exist to force Internet-bound network traffic through a proxy device (e.g., Policy Enforcement Point (PEP)) for URL content filtering and DNS filtering to limit a user's ability to connect to	5	
500.14(a)(3)	N/A	provide periodic, but at a minimum annual, cybersecurity awareness training that includes social engineering for all personnel that is updated to reflect risks identified by the covered entity in its risk assessment.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	
500.14(b)	N/A	Each class A company shall implement, unless the CISO has approved in writing the use of reasonably equivalent or more secure compensating controls:	Functional	No Relationship	N/A	N/A	N/A	0	No applicable SCF control Applicable to Class A Companies
500.14(b)(1)	N/A	an endpoint detection and response solution to monitor anomalous activity, including but not limited to lateral movement; and	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	
500.14(b)(1)	N/A	an endpoint detection and response solution to monitor anomalous activity, including but not limited to lateral movement; and	Functional	Intersects With	Endpoint Detection & Response (EDR)	END-06.2	Mechanisms exist to detect and respond to unauthorized configuration changes as cybersecurity incidents.	5	
500.14(b)(1)	N/A	an endpoint detection and response solution to monitor anomalous activity, including but not limited to lateral movement; and	Functional	Intersects With	Host Intrusion Detection and Prevention Systems (HIDS / HIPS)	END-07	Mechanisms exist to utilize Host-based Intrusion Detection / Prevention Systems (HIDS / HIPS), or similar technologies, to monitor for and	5	
500.14(b)(2)	N/A	a solution that centralizes logging and security event alerting.	Functional	Intersects With	Automated Tools for Real-Time Analysis	MON-01.2	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support near real-time analysis and incident escalation.	5	
500.14(b)(2)	N/A	a solution that centralizes logging and security event alerting.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5	
500.15	Encryption of Nonpublic Information	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.15(a)	N/A	As part of its cybersecurity program, each covered entity shall implement a written policy requiring encryption that meets industry	Functional	Intersects With	Publishing Security, Compliance &	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and	5	
500.15(a)	N/A	As part of its cybersecurity program, each covered entity shall implement a written policy requiring encryption that meets industry standards, to protect nonpublic information held or transmitted by the covered entity both in transit over external networks and at rest.	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	5	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.15(a)	N/A	As part of its cybersecurity program, each covered entity shall implement a written policy requiring encryption that meets industry standards, to protect nonpublic information held or transmitted by the covered entity both in transit over external networks and at rest.	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	5	
500.15(a)	N/A	As part of its cybersecurity program, each covered entity shall implement a written policy requiring encryption that meets industry standards, to protect nonpublic information held or transmitted by the covered entity both in transit over external networks and at rest.	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	5	
500.15(b)	N/A	To the extent a covered entity determines that encryption of nonpublic information at rest is infeasible, the covered entity may instead secure such nonpublic information using effective alternative compensating controls that have been reviewed and approved by the covered entity's CISO in writing. The feasibility of encryption and effectiveness of the compensating controls shall be reviewed by the CISO at least annually.	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	5	
500.15(b)	N/A	To the extent a covered entity determines that encryption of nonpublic information at rest is infeasible, the covered entity may instead secure such nonpublic information using effective alternative compensating controls that have been reviewed and approved by the covered entity's CISO in writing. The feasibility of encryption and effectiveness of the compensating controls shall be reviewed by the CISO at least annually.	Functional	Intersects With	Alternate Physical Protection	CRY-01.1	Cryptographic mechanisms exist to prevent unauthorized disclosure of information as an alternative to physical safeguards.	5	
500.15(b)	N/A	To the extent a covered entity determines that encryption of nonpublic information at rest is infeasible, the covered entity may instead secure such nonpublic information using effective alternative compensating controls that have been reviewed and approved by the covered entity's CISO in writing. The feasibility of encryption and effectiveness of the compensating controls shall be reviewed by the CISO at least annually.	Functional	Intersects With	Exception Management	GOV-02.1	Mechanisms exist to prohibit exceptions to standards, except when the exception has been formally assessed for risk impact, approved and recorded.	5	
500.15(b)	N/A	To the extent a covered entity determines that encryption of nonpublic information at rest is infeasible, the covered entity may instead secure such nonpublic information using effective alternative compensating controls that have been reviewed and approved by the covered entity's CISO in writing. The feasibility of encryption and effectiveness of the compensating controls shall be reviewed by the CISO at least annually.	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	5	
500.16	Incident Response Plan	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.16(a)	N/A	As part of its cybersecurity program, each covered entity shall establish written plans that contain proactive measures to investigate and mitigate cybersecurity events and to ensure operational resilience, including but not limited to incident response, business continuity and disaster recovery plans.	Functional	Intersects With	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	5	
500.16(a)	N/A	As part of its cybersecurity program, each covered entity shall establish written plans that contain proactive measures to investigate and mitigate cybersecurity events and to ensure operational resilience, including but not limited to incident response, business continuity and disaster recovery plans.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment;	5	
500.16(a)	N/A	As part of its cybersecurity program, each covered entity shall establish written plans that contain proactive measures to investigate and mitigate cybersecurity events and to ensure operational resilience, including but not limited to incident response, business continuity and disaster recovery plans.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)	N/A	Incident response plan. Incident response plans shall be reasonably designed to enable prompt response to, and recovery from, any cybersecurity event materially affecting the confidentiality, integrity or availability of the covered entity's information systems or the continuing functionality of any aspect of the covered entity's business or the goals of the incident response plan;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(i)	N/A		Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(ii)	N/A	the internal processes for responding to a cybersecurity event;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(iii)	N/A	the definition of clear roles, responsibilities and levels of decision-making authority;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(iv)	N/A	external and internal communications and information sharing;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(v)	N/A	identification of requirements for the remediation of any identified weaknesses in information systems and associated controls;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(vi)	N/A	documentation and reporting regarding cybersecurity events and related incident response activities;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(vii)	N/A	recovery from backups;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(viii)	N/A	preparation of root cause analysis that describes how and why the event occurred, what business impact it had, and what will be done to prevent updating of incident response plans as necessary.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
500.16(a)(1)(ix)	N/A		Functional	Intersects With	IRP Update	IRO-04.2	Mechanisms exist to regularly review and modify incident response practices to incorporate lessons learned, business process changes and industry developments, as necessary.	5	
500.16(a)(2)	N/A	Business continuity and disaster recovery (BCDR) plan. BCDR plans shall be reasonably designed to ensure the availability and functionality of the covered entity's information systems and material services and	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan	10	
500.16(a)(2)(i)	N/A	identify documents, data, facilities, infrastructure, services, personnel and competencies essential to the continued operations of the covered entity's business;	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
500.16(a)(2)(i)	N/A	identify documents, data, facilities, infrastructure, services, personnel and competencies essential to the continued operations of the covered entity's business;	Functional	Intersects With	Identify Critical Assets	BCD-02	Mechanisms exist to identify and document the critical Technology Assets, Applications, Services and/or Data (TAASD) that support essential missions and business functions.	5	
500.16(a)(2)(ii)	N/A	identify the supervisory personnel responsible for implementing each aspect of the BCDR plan;	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan	10	
500.16(a)(2)(ii)	N/A	identify the supervisory personnel responsible for implementing each aspect of the BCDR plan;	Functional	Intersects With	Recovery Operations Criteria	BCD-01.5	Business Continuity / Disaster Recover (BC/DR) plans that facilitate business continuity operations capable of meeting applicable Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	
500.16(a)(2)(ii)	N/A	identify the supervisory personnel responsible for implementing each aspect of the BCDR plan;	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	
500.16(a)(2)(ii)	N/A	identify the supervisory personnel responsible for implementing each aspect of the BCDR plan;	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	
500.16(a)(2)(iii)	N/A	include a plan to communicate with essential persons in the event of a cybersecurity-related disruption to the operations of the covered entity.	Functional	Subset Of	Business Continuity Management System	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets,	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - New York Department of Financial Services (NY DFS) 23NYCRR Part 500 (2023 Amendment 2)**

Focal Document URL: https://www.dfs.ny.gov/system/files/documents/2023/10/rf_fs_2amend23NYCRR500_text_20231101.pdf

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-state-ny-dfs-23-nycrr500-2023-amd2.pdf>

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.16(a)(2)(iii)	N/A	include a plan to communicate with essential persons in the event of a cybersecurity-related disruption to the operations of the covered entity, including employees, counterparties, regulatory authorities, third-party service providers, disaster recovery specialists, the senior governing body and any other persons essential to the recovery of documentation and data and the resumption of operations;	Functional	Intersects With	Recovery Operations Communications	BCD-01.6	Mechanisms exist to communicate the status of recovery activities and progress in restoring operational capabilities to designated internal and external stakeholders.	5	
500.16(a)(2)(iv)	N/A	include procedures for the timely recovery of critical data and information systems and to resume operations as soon as reasonably possible following a cybersecurity-related disruption to normal business activities;	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
500.16(a)(2)(iv)	N/A	include procedures for the timely recovery of critical data and information systems and to resume operations as soon as reasonably possible following a cybersecurity-related disruption to normal business activities;	Functional	Intersects With	Continue Essential Mission & Business Functions	BCD-02.2	Mechanisms exist to continue essential missions and business functions with little or no loss of operational continuity and sustain that continuity until full system restoration at primary processing and/or storage sites.	5	
500.16(a)(2)(v)	N/A	include procedures for backing up or copying, with sufficient frequency, information essential to the operations of the covered entity and storing such information offsite; and	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
500.16(a)(2)(v)	N/A	include procedures for backing up or copying, with sufficient frequency, information essential to the operations of the covered entity and storing such information offsite; and	Functional	Intersects With	Recovery Time / Point Objectives (RTO / RPO)	BCD-01.4	Mechanisms exist to facilitate recovery operations in accordance with Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	
500.16(a)(2)(v)	N/A	include procedures for backing up or copying, with sufficient frequency, information essential to the operations of the covered entity and storing such information offsite; and	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives	5	
500.16(a)(2)(vi)	N/A	identify third parties that are necessary to the continued operations of the covered entity's information systems.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
500.16(a)(2)(vi)	N/A	identify third parties that are necessary to the continued operations of the covered entity's information systems.	Functional	Intersects With	Identify Critical Assets	BCD-02	Mechanisms exist to identify and document the critical Technology Assets, Applications, Services and/or Data (TAASD) that support essential missions and business functions.	5	
500.16(b)	N/A	Each covered entity shall ensure that current copies of the plans or relevant portions therein are distributed or are otherwise accessible, including during a cybersecurity event, to all employees necessary to	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan	10	
500.16(b)	N/A	Each covered entity shall ensure that current copies of the plans or relevant portions therein are distributed or are otherwise accessible, including during a cybersecurity event, to all employees necessary to implement such plans.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	
500.16(c)	N/A	Each covered entity shall provide relevant training to all employees responsible for implementing the plans regarding their roles and responsibilities.	Functional	Equal	Contingency Training	BCD-03	Mechanisms exist to adequately train contingency personnel and applicable stakeholders in their contingency roles and responsibilities.	10	
500.16(d)	N/A	Each covered entity shall periodically, but at a minimum annually, test its:	Functional	No Relationship	N/A	N/A	N/A	0	
500.16(d)(1)	N/A	incident response and BCDR plans with all staff and management critical to the response, and shall revise the plan as necessary; and	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to	8	
500.16(d)(1)	N/A	incident response and BCDR plans with all staff and management critical to the response, and shall revise the plan as necessary; and	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	8	
500.16(d)(2)	N/A	ability to restore its critical data and information systems from backups.	Functional	Equal	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	10	
500.16(e)	N/A	Each covered entity shall maintain backups necessary to restore material operations. The backups shall be adequately protected from unauthorized alterations or destruction.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives	5	
500.16(e)	N/A	Each covered entity shall maintain backups necessary to restore material operations. The backups shall be adequately protected from unauthorized alterations or destruction.	Functional	Intersects With	Testing for Reliability & Integrity	BCD-11.1	Mechanisms exist to routinely test backups that verify the reliability of the backup process, as well as the integrity and availability of the data.	5	
500.16(e)	N/A	Each covered entity shall maintain backups necessary to restore material operations. The backups shall be adequately protected from unauthorized alterations or destruction.	Functional	Intersects With	Cryptographic Protection	BCD-11.4	Cryptographic mechanisms exist to prevent the unauthorized disclosure and/or modification of backup information.	5	
500.17	Notices to Superintendent	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.17(a)	N/A	Notice of cybersecurity incident.	Functional	No Relationship	N/A	N/A	N/A	0	
500.17(a)(1)	N/A	Each covered entity shall notify the superintendent electronically in the form set forth on the department's website as promptly as possible but in no event later than 72 hours after determining that a cybersecurity incident has occurred at the covered entity, its affiliates, or a third-party service provider.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
500.17(a)(1)	N/A	Each covered entity shall notify the superintendent electronically in the form set forth on the department's website as promptly as possible but in no event later than 72 hours after determining that a cybersecurity incident has occurred at the covered entity, its affiliates, or a third-party service provider.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	
500.17(a)(1)	N/A	Each covered entity shall notify the superintendent electronically in the form set forth on the department's website as promptly as possible but in no event later than 72 hours after determining that a cybersecurity incident has occurred at the covered entity, its affiliates, or a third-party service provider.	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	5	
500.17(a)(1)	N/A	Each covered entity shall notify the superintendent electronically in the form set forth on the department's website as promptly as possible but in no event later than 72 hours after determining that a cybersecurity incident has occurred at the covered entity, its affiliates, or a third-party service provider.	Functional	Intersects With	Regulatory & Law Enforcement Contacts	IRO-14	Mechanisms exist to maintain incident response contacts with applicable regulatory and law enforcement agencies.	5	
500.17(a)(2)	N/A	Each covered entity shall promptly provide to the superintendent any information requested regarding such incident. Covered entities shall have a continuing obligation to update the superintendent with material changes or new information previously unavailable.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
500.17(a)(2)	N/A	Each covered entity shall promptly provide to the superintendent any information requested regarding such incident. Covered entities shall have a continuing obligation to update the superintendent with material changes or new information previously unavailable.	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(a)(2)	N/A	Each covered entity shall promptly provide to the superintendent any information requested regarding such incident. Covered entities shall have a continuing obligation to update the superintendent with material changes or new information previously unavailable.	Functional	Intersects With	Legal Assessment of Investigative Inquires	CPL-05	Mechanisms exist to determine whether a government agency has an applicable and valid legal basis to request data from the organization and what further steps need to be taken, if necessary.	5	
500.17(a)(2)	N/A	Each covered entity shall promptly provide to the superintendent any information requested regarding such incident. Covered entities shall have a continuing obligation to update the superintendent with material changes or new information previously unavailable.	Functional	Intersects With	Investigation Access Restrictions	CPL-05.2	Mechanisms exist to support official investigations by provisioning government investigators with "least privileges" and "least functionality" to ensure that government investigators only have access to the Technology Assets, Applications, Services and/or Data (TAASD) needed	5	
500.17(b)	N/A	Notice of compliance.	Functional	No Relationship	N/A	N/A	N/A	0	
500.17(b)(1)	N/A	Annually each covered entity shall submit to the superintendent electronically by April 15 either:	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(b)(1)(i)	N/A	a written certification that:	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(b)(1)(i)(e)	N/A	certifies that the covered entity materially complied with the requirements set forth in this Part during the prior calendar year; and	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - New York Department of Financial Services (NY DFS) 23NYCRR Part 500 (2023 Amendment 2)**

Focal Document URL: https://www.dfs.ny.gov/system/files/documents/2023/10/rf_fs_2amend23NYCRR500_text_20231101.pdf

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-state-ny-dfs-23-nyccr500-2023-amd2.pdf>

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.17(b)(1)(i)(b)	N/A	shall be based upon data and documentation sufficient to accurately determine and demonstrate such material compliance, including, to the	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(b)(1)(i)(ii)	N/A	a written acknowledgment that:	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(b)(1)(i)(a)	N/A	acknowledges that, for the prior calendar year, the covered entity did not materially comply with all the requirements of this Part;	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(b)(1)(i)(b)	N/A	identifies all sections of this Part that the entity has not materially complied with and describes the nature and extent of such	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(b)(1)(i)(c)	N/A	provides a remediation timeline or confirmation that remediation has been completed.	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(b)(2)	N/A	Such certification or acknowledgment shall be submitted electronically in the form set forth on the department's website and shall be signed by	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(b)(3)	N/A	Each covered entity shall maintain for examination and inspection by the department upon request all records, schedules and other documentation and data supporting the certification or acknowledgment for a period of five years, including the identification of all areas, systems and processes that require or required material improvement, updating or redesign, all remedial efforts undertaken to address such areas, systems and processes, and remediation plans	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(c)	N/A	Notice and explanation of extortion payment. Each covered entity, in the event of an extortion payment made in connection with a cybersecurity event involving the covered entity, shall provide the superintendent electronically, in the form set forth on the department's website, with the following:	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
500.17(c)	N/A	Notice and explanation of extortion payment. Each covered entity, in the event of an extortion payment made in connection with a cybersecurity event involving the covered entity, shall provide the superintendent electronically, in the form set forth on the department's website, with the following:	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	
500.17(c)(1)	N/A	within 24 hours of the extortion payment, notice of the payment; and	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	
500.17(c)(2)	N/A	within 30 days of the extortion payment, a written description of the reasons payment was necessary, a description of alternatives to payment considered, all diligence performed to find alternatives to payment and all diligence performed to ensure compliance with	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	
500.18	Confidentiality	Information provided by a covered entity pursuant to this Part is subject to exemptions from disclosure under the Banking Law, Insurance Law, Financial Services Law, Public Officers Law or any other applicable State or Federal law.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	
500.18	Confidentiality	Information provided by a covered entity pursuant to this Part is subject to exemptions from disclosure under the Banking Law, Insurance Law, Financial Services Law, Public Officers Law or any other applicable State or Federal law.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	
500.19	Exemptions	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(a)	N/A	Limited exemption. Each covered entity with: ...shall be exempt from the requirements of sections 500.4, 500.5, 500.6, 500.8, 500.10, 500.14(a)(1), (a)(2), and (b), 500.15 and 500.16 of this Part.	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(a)(1)	N/A	fewer than 20 employees and independent contractors of the covered entity and its affiliates;	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(a)(2)	N/A	less than \$7,500,000 in gross annual revenue in each of the last three fiscal years from all business operations of the covered entity and the	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(a)(3)	N/A	less than \$15,000,000 in year-end total assets, calculated in accordance with generally accepted accounting principles, including assets of all affiliates,	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(b)	N/A	An employee, agent, wholly owned subsidiary, representative or designee of a covered entity, who is itself a covered entity, is exempt from this Part and need not develop its own cybersecurity program to	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(c)	N/A	A covered entity that does not directly or indirectly operate, maintain, utilize or control any information systems, and that does not, and is not required to, directly or indirectly control, own, access, generate, receive or possess nonpublic information shall be exempt from the requirements of sections 500.2, 500.3, 500.4, 500.5, 500.6, 500.7, 500.8, 500.10, 500.12, 500.14, 500.15 and 500.16 of this Part.	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(d)	N/A	A covered entity under article 70 of the Insurance Law that does not and is not required to directly or indirectly control, own, access, generate, receive or possess nonpublic information other than information relating to its corporate parent company (or affiliates) shall be exempt from the requirements of sections 500.2, 500.3, 500.4, 500.5, 500.6, 500.7, 500.8, 500.10, 500.12, 500.14, 500.15 and 500.16 of this Part.	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(e)	N/A	An individual insurance broker subject to Insurance Law section 2104 who qualifies for the exemption pursuant to subdivision 500.19(c) of this Part and has not, for any compensation, commission or other thing of value, acted or aided in any manner in soliciting, negotiating or selling any policy or contract or in placing risks or taking out insurance on behalf of another person for at least one year shall be exempt from the requirements of this Part, provided such individuals do not otherwise	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(f)	N/A	A covered entity that qualifies for any of the above exemptions pursuant to this section shall file electronically a Notice of Exemption in the form set forth on the department's website within 30 days of the determination that the covered entity is exempt.	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(g)	N/A	The following persons are exempt from the requirements of this Part, provided such persons do not otherwise qualify as a covered entity for purposes of this Part: persons subject to Insurance Law section 1110; persons subject to Insurance Law section 5904; any accredited	Functional	No Relationship	N/A	N/A	N/A	0	
500.19(h)	N/A	In the event that a covered entity ceases to qualify for an exemption, such covered entity shall have 180 days from the date that it ceases to so qualify to comply with all applicable requirements of this Part.	Functional	No Relationship	N/A	N/A	N/A	0	
500.20	Enforcement	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.20(a)	N/A	This regulation will be enforced by the superintendent pursuant to, and is not intended to limit, the superintendent's authority under any applicable laws.	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(b)	N/A	The commission of a single act prohibited by this Part or the failure to act to satisfy an obligation required by this Part shall constitute a violation hereof. Such acts or failures include, without limitation: the failure to secure or prevent unauthorized access to an individual's or an entity's nonpublic information due to noncompliance with any section of this Part; or	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(b)(1)	N/A		Functional	No Relationship	N/A	N/A	N/A	0	
500.20(b)(2)	N/A	the material failure to comply for any 24-hour period with any section of this Part;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)	N/A	the extent to which the covered entity has cooperated with the superintendent in the investigation of such acts;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(1)	N/A		Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(2)	N/A	the good faith of the entity;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(3)	N/A	whether the violations resulted from conduct that was unintentional or inadvertent, reckless or intentional and deliberate;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(4)	N/A	whether the violation was a result of failure to remedy previous examination matters requiring attention, or failing to adhere to any	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(5)	N/A	any history of prior violations;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(6)	N/A	whether the violation involved an isolated incident, repeat violations, systemic violations or a pattern of violations;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(7)	N/A	whether the covered entity provided false or misleading information;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(8)	N/A	the extent of harm to consumers;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(9)	N/A	whether required, accurate and timely disclosures were made to affected consumers;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(10)	N/A	the gravity of the violations;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(11)	N/A	the number of violations and the length of time over which they occurred;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(12)	N/A	the extent, if any, to which the senior governing body participated therein;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(13)	N/A	any penalty or sanction imposed by any other regulatory agency;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(14)	N/A	the financial resources, net worth and annual business volume of the covered entity and its affiliates;	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(15)	N/A	the extent to which the relevant policies and procedures of the company are consistent with nationally recognized cybersecurity frameworks,	Functional	No Relationship	N/A	N/A	N/A	0	
500.20(c)(16)	N/A	such other matters as justice and the public interest require.	Functional	No Relationship	N/A	N/A	N/A	0	
500.21	Effective Date	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.21(a)	N/A	This Part will be effective March 1, 2017. Covered entities will be required to annually prepare and submit to the superintendent a certification of compliance with New York State Department of Financial Services Cybersecurity Regulations under section 500.17(b) of this Part commencing February 15, 2018.	Functional	No Relationship	N/A	N/A	N/A	0	
500.21(b)	N/A	The second amendment to this Part shall become effective November 1, 2023.	Functional	No Relationship	N/A	N/A	N/A	0	
500.22	Transitional Periods	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(a)	N/A	Transitional period. Covered entities shall have 180 days from the effective date of this Part to comply with the requirements set forth in this Part, except as otherwise specified.	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(b)	N/A	The following provisions shall include additional transitional periods. Covered entities shall have:	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(b)(1)	N/A	one year from the effective date of this Part to comply with the requirements of sections 500.4(b), 500.5, 500.9, 500.12 and 500.14(b) of this Part;	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(b)(2)	N/A	eighteen months from the effective date of this Part to comply with the requirements of sections 500.6, 500.8, 500.13, 500.14(a) and 500.15 of this Part;	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(b)(3)	N/A	two years from the effective date of this Part to comply with the requirements of section 500.11 of this Part.	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(c)	N/A	Covered entities shall have 180 days from the effective date of the second amendment to this Part to comply with the new requirements	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(d)	N/A	The following provisions shall include different transitional periods. Covered entities shall have:	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(d)(1)	N/A	30 days from the effective date of the second amendment to this Part to comply with the new requirements specified in section 500.17 of this Part;	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(d)(2)	N/A	one year from the effective date of the second amendment to this Part to comply with the new requirements specified in sections 500.4, 500.15, 500.16 and 500.19(a) of this Part;	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(d)(3)	N/A	18 months from the effective date of the second amendment to this Part to comply with the new requirements specified in sections 500.5(a)(2), 500.7, 500.14(a)(2) and 500.14(b) of this Part; and	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(d)(4)	N/A	two years from the effective date of the second amendment to this Part to comply with the new requirements specified in sections 500.12 and 500.13(a) of this Part.	Functional	No Relationship	N/A	N/A	N/A	0	
500.22(e)	N/A	The new requirements specified in sections 500.19(e)-(h), 500.20, 500.21, 500.22 and 500.24 of this Part shall become effective November 1, 2023.	Functional	No Relationship	N/A	N/A	N/A	0	
500.23	Severability	If any provision of this Part or the application thereof to any person or circumstance is adjudged invalid by a court of competent jurisdiction, such judgment shall not affect or impair the validity of the other	Functional	No Relationship	N/A	N/A	N/A	0	
500.24	Exceptions From Electronic Filing and Submission Requirements	This is merely a section title without content.	Functional	No Relationship	N/A	N/A	N/A	0	
500.24(a)	N/A	A filer required to make an electronic filing or a submission pursuant to this Part may apply to the superintendent for an exemption from the requirement that the filing or submission be electronic by submitting a written request to the superintendent for approval at least 30 days	Functional	No Relationship	N/A	N/A	N/A	0	
500.24(b)	N/A	The request for an exemption shall:	Functional	No Relationship	N/A	N/A	N/A	0	
500.24(b)(1)	N/A	set forth the filer's DFS license number, NAIC number, Nationwide Multistate Licensing System number or institution number;	Functional	No Relationship	N/A	N/A	N/A	0	
500.24(b)(2)	N/A	identify the specific filing or submission for which the filer is applying for the exemption;	Functional	No Relationship	N/A	N/A	N/A	0	

FDE#	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
500.24(b)(3)	N/A	specify whether the filer is making the request for an exemption based upon undue hardship, impracticability or good cause, and set forth a	Functional	No Relationship	N/A	N/A	N/A	0	
500.24(b)(4)	N/A	specify whether the request for an exemption extends to future filings or submissions, in addition to the specific filing or submission identified in paragraph (2) of this subdivision.	Functional	No Relationship	N/A	N/A	N/A	0	
500.24(c)	N/A	The filer requesting an exemption shall submit, upon the superintendent's request, any additional information necessary for the superintendent to evaluate the filer's request for an exemption.	Functional	No Relationship	N/A	N/A	N/A	0	
500.24(d)	N/A	The filer shall be exempt from the electronic filing or submission requirement upon the superintendent's written determination so exempting the filer, where the determination specifies the basis upon	Functional	No Relationship	N/A	N/A	N/A	0	
500.24(e)	N/A	If the superintendent approves a filer's request for an exemption from the electronic filing or submission requirement, then the filer shall make a filing or submission in a form and manner acceptable to the superintendent.	Functional	No Relationship	N/A	N/A	N/A	0	